

INFORMATION SYSTEM SECURITY AND AUDIT

General Objective:

Safeguarding Digital Assets and Protecting Information Systems

The Guide provides Knowledge in the following Areas:

- Information system
- Information system Vulnerabilities, threats and risks
- Information system Security Control and Governance
- Continuity of Computer Operations
- Audit



2024

FOREWORD

Cybercrime appears unstoppable, there are thousands of cybercrimes every year, ranging in cost from a few hundred dollars to the millions. From the report compiled by Z. Smith et.al (2021), since 2018, it is estimated that the cost of global cybercrime reached over \$1 trillion. The estimated the monetary loss from cybercrime was approximately \$945 billion, this average cost rose steadily from \$300 billion in 2013 to \$475 billion in 2014 to \$522 billion in 2018.

The risk of cybercrime to operations and profits continues to grow for many organizations. Global spending on cyber security, was expected to exceed \$145 billion in 2020.

In the research for smith report a total of 1,500 companies were surveyed, only 4% claimed that they did not experience any sort of cyber incident in 2019. The damage from malware and spyware represented the highest cost to organizations, closely followed by data breaches. Affected companies said the biggest non-monetary loss was in productivity and lost work hours.

Despite this, it was found that most organizations do not have plans in place to reduce the effect of security incidents on their operations. From the report slightly more than half of the surveyed organization said they do not have plans to both prevent and respond to a cyber-incident.

While many cyber-attacks can be managed in house, major incidents often require contracting with outside consultants at high rates, forming a significant portion of the cost of a large-scale incident. From the report Only 213 out of 1,332 surveyed companies reported that they dealt with cyber incidents without third-party support. Typically, they relied on cyber security organizations or response teams to help with **CONTAINMENT, RECOVERY AND REMEDIATION**, in most of these cases, consultants were used to assist in *containment, recovery and remediation*.

On December 14, 2021, Google asked its 2.6 billion Chrome users to update the browser urgently to fix a "critical" bug that was being exploited by hackers.

From a report compiled by Communications Authority of Kenya, National Kenya Computer Incident Response Team/Coordination (KE-CIRT/CC), in period July - September 2021, the National KE-CIRT/CC detected 143,040,599 cyber threat events, which was a 268.883% increase from the 38,776,699 threat events detected in the previous period, April - June 2021.

This increase in cyber threat events detected is attributed to the significant increase in targeted attacks at critical systems and services; increased activity by ransom ware groups; adoption of more sophisticated tools by cyber threat actors; increased targeted attacks at Internet of Things (IoT) devices; increased exploits of third-party mobile application vulnerabilities; increased targeted attacks at unsecured infrastructure; and increased adoption of botnet and Distributed Denial of Service (DDoS) attack techniques.

While opening Cyber Security Strategy 2022 – 2026 workshop in Naivasha in June 2022, interior and National Government Coordination Cabinet Secretary (CS), Dr. Fred Matiang'i, said the increase in technology and growth of the same has soared transactions from 1.9trillion 10 years ago to over 6.8trillion in 2022, indicating an urgent need to protect this space.

Bernard Mokua
Information system

Chapter One

INTRODUCTION TO INFORMATION SYSTEMS

System is a set of interacting or interdependent components forming an integrated whole or a set of elements (often called '*components*') and relationships which are different from relationships of the set or its elements to other elements or sets.

Information System is a set of interrelated components that collect, store and process data then distribute information to support decision making and control in an organization.

Data consists of the raw facts about events/Persons/Objects in the organization before they are organized into an understandable and useful form for humans.

Data processing, Manipulation of data by a computer. Any use of computers to perform defined operations on data can be included under data processing.

Information is data that has been processed in such a way as to be meaningful to the person who receives it. It provides context for data and enables decision making processes.

Uses of Information

Businesses and other organizations need information for many purposes: we have summarized the five main uses in the table below.

Decision-making

i. **Strategic information:** used to help plan the objectives of the business as a whole and to measure how well those objectives are being achieved. Examples of strategic information include:

- Profitability of each part of the business
- Size, growth and competitive structure of the markets in which a business operates

ii. **Tactical Information:** this is used to decide how the resources of the business should be employed.

Examples include:

- Information about business productivity (e.g. units produced per employee; staff turnover)

iii. **Operational:** this information is used to make sure that specific operational tasks are carried out as planned/intended (i.e. things are done properly).

For example, a production manager will want information about the extent and results of quality control checks that are being carried out in the manufacturing process.

Cyber space

A global domain within the information environment consisting of the **interdependent** network of information systems infrastructures including the Internet, telecommunications networks, computer systems, and embedded processors and controllers i.e. concept describing a widespread interconnected digital technology.

Cyberspace is an embodied switched network for moving information traffic further characterized by varying degrees of access, navigation, information- activity, augmentation (and trust), and these characteristics can be taken into account sufficiently for drawing legal conclusions.

The control of cyberspace is thus important not only because of the actions of individual participants but because the infrastructure of cyberspace is now fundamental to the functioning of national and international security systems, trade networks, emergency services, basic communications, and other public and private.



Cyberattack

A cyber attack refers to an action designed to target a *computer or any element of a computerized information system* to change, destroy, or steal data, as well as exploit or harm a network. Cyber-attacks have been on the rise, in sync with the digitization of business that has become more and more popular in recent years.

Why do people launch cyber-attacks?

Cybercrime has increased every year as people try to benefit from vulnerable business systems.

When attackers strike, they typically have one or more of the following goals:

- User credentials—enable attackers to enter systems without having to break-in. Instead, attackers can just use stolen user credentials to access resources easily, hiding as a legitimate user. Once inside a system, criminals often try to escalate the privileges of the user they've stolen credentials from or to create a new user entirely.
- Personally identifiable information (PII)—information like financial details, ID numbers, or birth dates, is valuable to criminals. They may steal personally identifiable information to sell to others or use it for other crimes, such as identity theft or blackmail.
- Intellectual property or sensitive information—this information is valuable to competitors and enemy nation-states. Criminals may attempt to steal this information to sell to others or to use

for personal gain. Employee theft of this data is a significant risk since employees are already inside your systems and are more familiar with where this data may be stored.

- **Revenge**—this is typically done by angry users, ex-employees, or ‘hacktivists’ that want to punish or shame a company. These attackers may take down services, deface sites, or harass other users in an attempt to harm their target.

Evolution of information from office to a battle field

As government and civilian organizations continue to increase their dependency on networked computers that control communications, infrastructures, and weapons systems, the vulnerabilities of exploitation, manipulation, and corruption likewise increase.

The debate surrounding the changing nature of conflict in the modern era continues with the introduction of a new element, the cyber dimension. Cyber warfare represents a fundamental transformation in the very nature of the concept of conflict itself, not only changing the weapons of modern conflict, but radically shifting the nature of the wartime battlefield.

Over the past decade, the entire global cyber space has turned into a battlefield. The raging war — with no end in sight — is affecting everyone using internet-based services and technologies. Operators of critical infrastructure from energy companies, to banks, and to telecommunications providers are under an unrelenting onslaught

Cyber Warfare

Cyber warfare is usually defined as a cyber-attack or series of attacks that target a country. It has the potential to wreak havoc on government and civilian infrastructure and disrupt critical systems, resulting in damage to the state and even loss of life. Cyber warfare typically involves a nation-state perpetrating cyber-attacks on another, but in some cases, the attacks are carried out by terrorist organizations or non-state actors seeking to further the goal of a hostile nation.

Cyber warfare is one of the newest elements in contemporary warfare, however, this new advancement is continuously evolving and it can be challenging, at times, to stay abreast of all the new developments. In an age when individuals voluntarily transmit and receive copious amounts of personal data, exploiting electronic devices to alter or obtain information has become a crucial new tactic of conflict known as the ‘fifth dimension battlefield, after air, sea, land and outer space’ and has, arguably, become vital in achieving states’ success today.

There is no clear set date of when cyber warfare began but a key milestone was in Kosovo in 1999. Whilst Vietnam was the world’s first TV war, Kosovo became its first cyber war (Geers, 2008). NATO Kosovo operation was a major challenge in the history of the Atlantic alliance. For the first time, a defensive alliance launched a military campaign to avoid a humanitarian tragedy outside its own borders

And despite many challenges, including the use of cyber warfare, NATO prevailed. Numerous pro-Serbian hackers attacked NATO’s internet infrastructure with the goal to disrupt military operations. Whilst some states declared the cyber-attacks had no impact on their overall war effort, the U.K.

admitted to having lost at least some database information, these attacks where the first sign of things to come and the potential power cyberware would have.

The cyber domain is unique in that it is all new, manmade and subject to even more rapid technological evolution than other domains. More importantly, the non-existent boundaries in cyberspace create an environment where states can simultaneously be allies and adversaries.

As such, cyberspace has become gradually well-defined in a military context by a variety of state governments. However, cyber-attacks are not just restricted to local governments but can also rapidly spread worldwide without the need of human capital, as “cyber warfare has no borders and is able to attack multiple destinations simultaneously”. The U.S. Department of Defence termed cyberspace a “global domain within the information environment consisting of the interdependent network of information technology infrastructures, including the internet, telecommunications networks, computer systems, and embedded processors and controllers”.

7 Types of Cyber Warfare Attacks

Here are some of the main types of cyber warfare attacks.

- Espionage

Refers to monitoring other countries to steal secrets.

- Sabotage

Hostile governments or terrorists may steal information, destroy it, or leverage insider threats such as dissatisfied or careless employees, or government employees with affiliation to the attacking country.

- Denial-of-service (DoS) Attacks

DoS attacks prevent legitimate users from accessing a website by flooding it with fake requests and forcing the website to handle these requests.

- Electrical Power Grid

Attacking the power grid allows attackers to disable critical systems, disrupt infrastructure, and potentially result in bodily harm

- Propaganda Attacks

Attempts to control the minds and thoughts of people living in or fighting for a target country.

- Economic Disruption

Attackers can target computer networks of economic establishments such as stock markets, payment systems, and banks to steal money or block people from accessing the funds they need.

- Surprise Attacks

The point is to carry out a massive attack that the enemy isn't expecting, enabling the attacker to weaken their defenses. This can be done to prepare the ground for a physical attack in the context of hybrid warfare.

Securing Cyber Space

Increased connectivity of people and devices to the Internet and to each other has created an ever-expanding attack surface that extends throughout the world. As a result, cyberspace has become the most active threat domain in the world and the most dynamic threat to the Homeland.

Cybersecurity

In the modern age of technology, businesses must safeguard themselves from cyber-attacks that can cause significant harm to their information systems.

cybersecurity is the process of protecting information systems from unauthorized access, compromise, theft, and damage.

A compromised information system can have severe and far-reaching consequences for a company, including reduced productivity, financial losses, loss of customer trust, legal consequences, and regulatory non-compliance.

Financial Losses: Many cyber-attacks result in significant financial losses for businesses. These losses can come from theft of sensitive financial data, system downtime, and business interruption. A company's financial resources can be depleted if a cyber-attack is successful, leading to bankruptcy.

Reputation Damage: Customer data breaches can cause a loss of public confidence in a business, and the negative publicity can take years to recover from. Once the public's trust is lost, it is difficult to regain. A breach of customer information can cause a loss of customer trust, resulting in lost revenue and profits.

Compliance Requirement: With increasing regulations such as the GDPR and the CCPA, businesses must comply with regulatory requirements, which include cybersecurity standards, data privacy, and breach notification obligations. Businesses that fail to comply risk hefty fines and legal penalties. Cybersecurity measures are necessary for businesses to meet regulatory requirements and avoid legal complications.

Operational Efficiency: Cyber-attacks can also cause operational inefficiencies, leading to system downtime and business interruption. When a company's information system is compromised, the system can become slow, leading to reduced productivity, and in some cases, system shutdowns. Additionally, the information system may be manipulated or entirely taken over by attackers, allowing them to access sensitive data such as personal information, financial records, and intellectual property.

Therefore, it is crucial for companies to prioritize information security and take appropriate measures to protect their systems, data, and customers.

Chapter Two

CYBERSECURITY CONCEPTS

Before computer automation, data about individuals or organizations were maintained and secured as paper records dispersed in separate business or organizational units. With the advent computerized Information systems concentrate data in computer files that can potentially be accessed by large numbers of people and by groups outside of the organization.

When large amounts of data are stored in electronic form they are vulnerable to many more kinds of threats than when they exist in manual form. Through communications networks, information systems in different locations can be interconnected. The potential for unauthorized access, abuse, or fraud is not limited to a single location but can occur at any access point in the network.

The three fundamental cybersecurity concepts are Vulnerabilities, Threats, and Risks. All *risks, threats, and vulnerabilities* are measured for their potential capability to compromise one or all of the AIC principles

2.1. VULNERIBILITY

A vulnerability is a flaw or weakness in an asset's design, implementation, or operation and management that could be exploited by a threat.

For example, a vulnerability is leaving your car unlocked in a public parking lot. Leaving the doors unlocked does not necessarily mean harm will occur, but it is an opening for someone to go through your car.

A vulnerability, in information technology (IT), is a flaw in code or design that creates a potential point of security compromise for an endpoint or network. Vulnerabilities create possible attack vectors, through which an intruder could run code or access a target system's memory.

The exposure of an information resource is the harm, loss, or damage that can result if a threat compromises that resource. An information resource's vulnerability is the possibility that the system will be harmed by a threat.

Hence a *software, hardware, or procedural weakness* that may provide an attacker the open door he is looking for to enter a computer or network and have unauthorized access to resources within the environment.

Vulnerability characterizes the absence or weakness of a safeguard that could be exploited. Without strong safeguards, valuable data could be lost, destroyed, or could fall into the wrong hands, revealing important trade secrets or information that violates personal privacy.

One of the biggest causes of cyber and information security vulnerabilities is that systems and software are not regularly updated.

E.g.: a service running on a server, unpatched applications or operating system software, unrestricted modem dial-in access, an open port on a firewall, lack of physical security etc.

The four main types of vulnerabilities in information systems security are

- **Network Vulnerabilities.** These are issues with a network's hardware or software that expose it to possible intrusion by an outside party. Examples include insecure Wi-Fi access points and poorly-configured firewalls.
- **Operating System Vulnerabilities.** These are vulnerabilities within a particular operating system that hackers may exploit to gain access to an asset the OS is installed on—or to cause damage. Examples include default super user accounts that may exist in some OS installs and hidden backdoor programs.
- **Human Vulnerabilities.** The weakest link in many cybersecurity architectures is the human element. User errors can easily expose sensitive data, create exploitable access points for attackers, or disrupt systems.
- **Process Vulnerabilities.** Some vulnerabilities can be created by specific process controls (or a lack thereof). One example would be the use of weak passwords (which may also fall under human vulnerabilities)

Network vulnerabilities

Network security vulnerability is a broad category of flaws, potential exploits, and weaknesses in system hardware, software, administration, and organizational policies or processes.

Large public networks such as the Internet are more vulnerable than internal networks because they are virtually open to anyone. The Internet is so huge that when abuses do occur, they can have an enormously widespread impact. When the Internet becomes part of the corporate network, the organization's information systems are even more vulnerable to actions from outsiders.

Computers that are constantly connected to the Internet by cable modems or Digital Subscriber Line (DSL) are more open to penetration by outsiders because they use fixed Internet addresses where they can be easily identified. (With dial-up service, a temporary Internet address is assigned for each session.) A fixed Internet address creates a fixed target for hackers.

Vulnerability has also increased from widespread use of e-mail and instant messaging (IM). E-mail can contain attachments that serve as springboards for malicious software or unauthorized access to internal corporate systems. Employees may use e-mail messages to transmit valuable trade secrets, financial data, or confidential customer information to unauthorized recipients. Popular instant messaging applications for consumers do not use a secure layer for text messages, so they can be intercepted and read by outsiders during transmission over the public Internet. IM activity over the Internet can in some cases be used as a back door to an otherwise secure network

Wireless security challenges

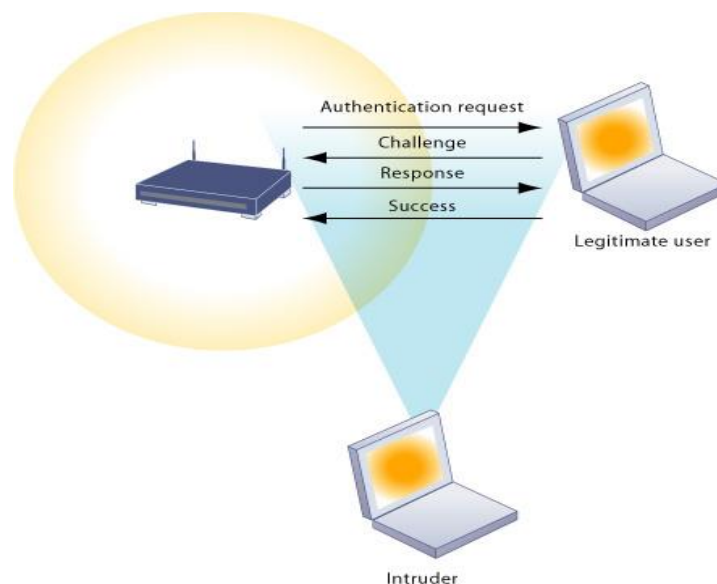
Wireless networks using radio-based technology are even more vulnerable to penetration because radio frequency bands are easy to scan. Although the range of Wireless Fidelity (Wi-Fi) networks is only

several hundred feet, it can be extended up to one-fourth of a mile using external antennae. Local area networks (LANs) that use the 802.11b (Wi-Fi) standard can be easily penetrated by outsiders armed with laptops, wireless cards, external antennae, and freeware hacking software. Hackers use these tools to detect unprotected networks, monitor network traffic, and in some cases, gain access to the Internet or to corporate networks.

Wireless networks in many locations do not have basic protections against war driving, in which eavesdroppers drive by buildings or park outside and try to intercept wireless network traffic.

Many Wi-Fi networks can be penetrated easily by intruders using sniffer programs to obtain an address to access the resources of a network without authorization.

Intruders can also use the information they have gleaned about Internet Protocol (IP) addresses and SSIDs to set up rogue access points on a different radio channel in physical locations close to users to force a user's radio NIC to associate with the rogue access point. Once this association occurs, hackers using the rogue access point can capture the names and passwords of unsuspecting users.



Network security vulnerabilities may be physical or non-physical.

Physical

Protection of physical systems includes **data center security** and preventing intruders' unauthorized access. Server rooms need to be locked tight and under 24-hour surveillance. Entry should be monitored using biometrics scanners. Access must be highly-controlled and only granted to parties that have a certified need to enter the facility.

Non-physical

Non-physical threats are any vulnerabilities in data storage, data processing, and software applications.

3 Types of Network Security Vulnerabilities

At the highest level, network security vulnerabilities may be separated into three broad categories of hardware issues, software issues, and human security issues.

Hardware-based network security vulnerability

Any device connected to a network poses a security risk if managed improperly. Hackers who gain unauthorized access to a physical device can easily install malicious software code on it by downloading the software to the device or using a USB thumb drive.

Criminals are clever. Some mailed USB drives to targets as free "gifts." When these USB drives are used, they automatically install malware that allows network penetration.

Any device that leaves a secured premise is vulnerable to theft. Mobile devices need strong password protection and encryption to protect sensitive data.

Other hardware vulnerabilities include firewalls, Wi-Fi routers, IoT devices, and employees' use of unauthorized devices.

Software-based network security vulnerability

Software vulnerabilities include operating systems and applications. Software may not be updated or contain bugs with security holes. Application plug-ins, downloadable apps, and add-ons for content management systems are especially vulnerable.

Employees' use of unauthorized software creates a security risk. For example, something seemingly innocent as downloading the Chinese spyware called Tik Tok, which is masquerading as a social media app, may make an entire network vulnerable. The Chairman of the FCC, Brendan Carr, called for a **complete ban of TikTok**. This software should never be used in any enterprise setting.

Application vulnerability

An application vulnerability is a system flaw or weakness in an application that could be exploited to compromise the security of the application. These crimes target the confidentiality, integrity, or availability (known as the "CIA triad") of resources possessed by an application, its creators, and its users.

Human-based network security vulnerability

Human security issues are the most prevalent as hackers frequently gain unauthorized access to network systems using these methods. Access may be obtained through trickery and techniques of human engineering, such as phishing with fake emails to obtain login credentials.

How to Identify Network Security Vulnerabilities?

Proactive efforts to identify security risks include:

- ✓ Conducting regular security audits
- ✓ Network traffic monitoring
- ✓ Tracking trends using threat intelligence data
- ✓ Penetration testing
- ✓ Authorized permission management
- ✓ Using extensive firewalls

2.2. THREAT

In a broad sense, a threat is anything that could exploit a vulnerability and hinder the confidentiality, integrity, and availability of anything valuable. Threats can either be natural or human-made and accidental or deliberate. In our car example, the owner of the car did not lock their door, so a carjacker could exploit the opportunity. This means the threat is human-made and deliberate.

A threat is any potential danger to information or systems. A threat is a possibility that someone (person, s/w) would identify and exploit the vulnerability.

The entity that takes advantage of vulnerability is referred to as a threat agent. E.g.: A threat agent could be an intruder accessing the network through a port on the firewall

Information systems are frequently exposed to various types of threats which can cause different types of damages that might lead to significant financial losses. Information security damages can range from small losses to entire information system destruction. The effects of various threats vary considerably: some affect the confidentiality or integrity of **data** while others affect the **availability of a system**.

Currently, organizations are struggling to understand what the threats to their information assets are and how to obtain the necessary means to combat them which continues to pose a challenge. To improve our understanding of security threats, we propose a security threat classification model which allows us to study the threats class impact instead of a threat impact as a threat varies over time.

Cybersecurity threats come in various types and forms:

Cybercrime is a criminal activity that primarily occurs online or through electronic means.

Cybercriminals use the internet to access personal or organizational data. Cybercrime can take several forms, including identity theft, phishing, fraud, hacking, and cyberstalking. The purpose of cybercrime is to steal, damage, or disrupt personal and organizational data.

- Identity Theft

Identity theft occurs when personal information, such as name, social security number, credit card details, or bank account details, is stolen. Cybercriminals use the stolen information to access personal accounts, buy products or services, or obtain credit. Identity theft can have severe consequences on individuals, as it can result in financial loss, damaged credit, and a damaged reputation.

- Fraud

Fraud is a criminal activity that involves deceiving individuals for financial gain. Cybercriminals often use the internet to carry out fraudulent activities, such as fake investment opportunities, lottery scams, and employment scams. The ultimate goal of fraud is to obtain personal or organizational assets, such as money or sensitive information.

- Hacking

Hacking refers to the unauthorized access of computer systems or networks. Cybercriminals use various techniques, such as SQL injection, brute force attacks, and phishing attacks, to gain access to personal or organizational data. Hacking can result in the theft of sensitive information, such as credit card details, intellectual property, or personal data.

Types of Hacking/Hackers

There are typically four key drivers that lead to bad actors hacking websites or systems:

- ✓ financial gain through the theft of credit card details or by defrauding financial services
- ✓ corporate espionage
- ✓ to gain notoriety or respect for their hacking talents
- ✓ state-sponsored hacking that aims to steal business information and national intelligence

On top of that, there are politically motivated hackers—or hacktivists—who aim to raise public attention by leaking sensitive information, such as Anonymous, LulzSec, and WikiLeaks.

A few of the most common types of hackers that carry out these activities involve:

Black hat hackers

- Black hat hackers are the "bad guys" of the hacking scene. They go out of their way to discover vulnerabilities in computer systems and software to exploit them for financial gain or for more malicious purposes, such as to gain reputation, carry out corporate espionage, or as part of a nation-state hacking campaign.

These individuals' actions can inflict serious damage on both computer users and the organizations they work for. They can steal sensitive personal information, compromise computer and financial systems, and alter or take down the functionality of websites and critical networks.

- White hat hackers

White hat hackers can be seen as the "good guys" who attempt to prevent the success of black hat hackers through proactive hacking. They use their technical skills to break into systems to assess and test the level of network security, also known as ethical hacking. This helps expose vulnerabilities in systems before black hat hackers can detect and exploit them.

The techniques white hat hackers use are similar to or even identical to those of black hat hackers, but these individuals are hired by organizations to test and discover potential holes in their security defenses.

- Grey hat hackers

Grey hat hackers sit somewhere between the good and the bad guys. Unlike black hat hackers, they attempt to violate standards and principles but without intending to do harm or gain financially. Their actions are typically carried out for the common good. For example, they may exploit a vulnerability to raise awareness that it exists, but unlike white hat hackers, they do so publicly. This alerts malicious actors to the existence of the vulnerability.

Devices Most Vulnerable to Hacking

- ✓ Smart devices

Smart devices, such as smartphones, are lucrative targets for hackers. Android devices, in particular, have a more open-source and inconsistent software development process than Apple devices, which puts them at risk of data theft or corruption. However, hackers are increasingly targeting the millions of devices connected to the Internet of Things (IoT).

- ✓ Webcams

Webcams built into computers are a common hacking target, mainly because hacking them is a simple process. Hackers typically gain access to a computer using a Remote Access Trojan (RAT) in rootkit malware, which allows them to not only spy on users but also read their messages, see their browsing activity, take screenshots, and hijack their webcam.

- ✓ Routers

Hacking routers enables an attacker to gain access to data sent and received across them and networks that are accessed on them. Hackers can also hijack a router to carry out wider malicious acts such as distributed denial-of-service (DDoS) attacks, Domain Name System (DNS) spoofing, or cryptomining.

- ✓ Email

Email is one of the most common targets of cyberattacks. It is used to spread malware and ransomware and as a tactic for phishing attacks, which enable attackers to target victims with malicious attachments or links.

- ✓ Jailbroken phones

Jailbreaking a phone means removing restrictions imposed on its operating system to enable the user to install applications or other software not available through its official app store. Aside from being a violation of the end-user's license agreement with the phone developer, jailbreaking exposes many vulnerabilities. Hackers can target jailbroken phones, which allows them to steal any data on the device but also extend their attack to connected networks and systems.

Ethical Hacking

Ethical hacking refers to the actions carried out by white hat security hackers. It involves gaining access to computer systems and networks to test for potential vulnerabilities, and then fixing any identified weaknesses. Using these technical skills for ethical hacking purposes is legal, provided the individual has written permission from the system or network owner, protects the organization's privacy, and reports all weaknesses they find to the organization and its vendors.

- Cyberstalking

Cyberstalking is a type of cybercrime in which an individual uses electronic communication to harass or intimidate another person. This is done with the help of email, social media, forums, or other internet-based mechanisms. It can take the form of threats, humiliating messages, or constant

annoyance that can cause emotional distress to the victim. The harasser can be someone known to the victim or a complete stranger.

Cyber threat categories

Although the landscape is always changing, most incidents fall into a few common categories:

Insider threats

Not all cybersecurity incidents originate externally. Insider threats occur when individuals within an organization — employees, contractors, partners, etc. — intentionally or unintentionally compromise security. These events are especially dangerous because insiders often have legitimate and privileged access to sensitive information, making it easier to cause harm or expose data.

Insider threats come in two forms:

Malicious insiders: These individuals intentionally exploit their access to steal data, sabotage systems, or leak confidential information. Motivations can range from financial gain to revenge or corporate espionage. For example, a disgruntled employee with access to critical systems might delete valuable data or sell trade secrets to competitors.

Unintentional insiders: These threats arise when employees unknowingly create security risks through careless actions, such as falling victim to phishing attacks, using weak passwords, or mishandling sensitive data.

Malware

Malware, or “malicious software,” is a general term describing any program created to disrupt or unlawfully retrieve information from a computer system.

Attackers use malware to invade, damage or disrupt computer systems, networks, and devices. Their goal may be data exfiltration, direct financial gain, corporate espionage, revenge or sabotage (for example in the case of disgruntled employees), or hacktivism.

Although it comes in many forms, malware typically falls into the following categories:

Viruses: A virus attaches itself to a legitimate file or program and spreads to other systems when the infected file is shared or executed. Once activated, viruses can corrupt files, steal data, or damage systems.

Trojan horses: Disguised as legitimate software, trojans trick users into downloading and installing them. Once inside the system, they create backdoors for attackers to steal data, install more malware, or take control of the device.

Worms: Unlike viruses, worms can replicate themselves and spread across networks without any human interaction. Worms often exploit vulnerabilities in operating systems, quickly infecting large numbers of devices and causing widespread damage.

Botnet: A botnet is a network of compromised devices, often controlled remotely by cybercriminals. These “bots” can launch large-scale strikes such as distributed denial-of-service (DDoS) attacks, which overwhelm systems with illegitimate traffic to take them offline.

Ransomware: This form of malware encrypts the victim's files or locks them out of information systems, demanding payment in exchange for their safe return. Ransomware attacks can severely disrupt operations by holding critical data hostage until the ransom is paid.

Social engineering

Social engineering

Social engineering is a type of cyberattack that relies on human interaction to manipulate individuals into revealing sensitive information or performing actions that compromise security. Rather than exploiting software vulnerabilities, social engineering preys on human psychology, making it one of the most challenging threats to prevent.

Frequent examples include:

Phishing: Attackers send deceptive emails or messages that appear legitimate, tricking individuals into clicking malicious links, providing login credentials, or downloading malware. Phishing is one of the most widespread social engineering tactics, often targeting employees with privileged accounts.

Fraud: This involves tricking individuals or organizations into sharing confidential information or making unauthorized payments. Attackers may pose as trusted entities, such as vendors or executives, to deceive their targets.

Scams: These attacks involve convincing individuals to provide sensitive information or transfer money under false pretenses, often by creating a sense of urgency or fear. Common scams include fake tech support calls or lottery scams.

Influence campaigns: Attackers manipulate public opinion or decision-making processes through misinformation or disinformation, often using social media. These campaigns can destabilize businesses or even governments by spreading false information to large audiences.

System design failure

A system design failure is a security flaw within a computer system or application that a bad actor exploits to gain access. For instance, coding errors and misconfigurations during the development process may leave gaps in an application's security posture. If the application isn't updated after deployment, hackers could leverage these open vulnerabilities to their advantage.

One of the most common ways cybercriminals do so is through a [Structured Query Language \(SQL\)](#) injection. SQL is a standard language used to query databases. Bad actors try to insert an SQL query into regular input or form fields, passing it to the application's underlying database. This can lead to unauthorized access to sensitive data, corruption, or even a complete database takeover.

Examples of Threats and Countermeasures

Denial of Service (DoS/DDoS)

A denial-of-service attack (DoS attack) or distributed denial-of-service attack (DDoS attack) is an attempt to make a computer resource unavailable to its intended users. Although the means to, motives for, and targets of a DoS attack may vary, it generally consists of the concerted, malevolent efforts of a person or persons to prevent an Internet site or service from functioning efficiently or at all, temporarily or indefinitely.

The purpose of DoS attacks is to force the targeted computer(s) to reset, or consume its resources so that it can no longer provide its intended service

Types of DoS Attacks

A Denial of Service (DoS) attack can be perpetrated in a number of ways. There are five basic types of attack:

- Consumption of computational resources, such as bandwidth, disk space, or CPU time;
- Disruption of configuration information, such as routing information;
- Disruption of state information, such as unsolicited resetting of TCP sessions;
- Disruption of physical network components.
- Obstructing the communication media between the intended users and the victim so that they can no longer communicate adequately.

Countermeasures

Unfortunately, there are no effective ways to prevent being the victim of a DoS or DDoS attack, but there are steps you can take to reduce the likelihood that an attacker will use your computer to attack other computers:

- Install and maintain anti-virus software.
- Install a firewall, and configure it to restrict traffic coming into and leaving your computer.
- Follow good security practices for distributing your email address.
-

Buffer Overflows

A buffer overflow is an anomalous condition where a process attempts to store data beyond the boundaries of a fixed-length buffer. The result is that the extra data overwrites adjacent memory locations. The overwritten data may include other buffers, variables and program flow data and may cause a process to crash or produce incorrect results. They can be triggered by inputs specifically designed to execute malicious code or to make the program operate in an unintended way. As such, buffer overflows cause many software vulnerabilities and form the basis of many exploits.

Buffer Overflow Techniques

- *Stack Buffer Overflow*
 - A stack buffer overflow occurs when a program writes to a memory address on the program's call stack outside of the intended data structure; usually a fixed length buffer.
 - Stack buffer overflow bugs are caused when a program writes more data to a buffer located on the stack than there was actually allocated for that buffer. This almost always results in corruption of adjacent data on the stack, and in cases where the overflow was triggered by mistake, will often cause the program to crash or operate incorrectly.
 - A technically inclined and malicious user may exploit stack-based buffer overflows to manipulate the program
- *Heap Buffer Overflow*
 - A heap overflow is another type of buffer overflow that occurs in the heap data area. Memory on the heap is dynamically allocated by the application at run-time and typically contains program data.
 - Exploitation goes as follows: If an application copies data without first checking to see if it fits into the chunk (blocks of data in the heap), the attacker could supply the application

with a piece of data that is too large, overwriting heap management information (metadata) of the next chunk. This allows an attacker to overwrite an arbitrary memory location with four bytes of data. In most environments, this may allow the attacker control over the program execution.

Countermeasure

- Choice of programming language
- Use of safe libraries
- Stack-smashing protection which refers to various techniques for detecting buffer overflows on stack-allocated variables. The most common implementation being StackGuard, and SSP
- Executable space protection which is the marking of memory regions as non-executable, such that an attempt to execute machine code in these regions will cause an exception. It makes use of hardware features such as the NX bit (Non Execute bit).
- Address space layout randomization: A technique which involves arranging the positions of key data areas, usually including the base of the executable and position of libraries, heap, and stack, randomly in a process' address space.

Spoofing/Masquerading

A spoofing attack is a situation in which one person or program successfully masquerades as another by falsifying data and thereby gaining an illegitimate advantage.

Popular Spoofing Techniques include:

- *Man-in-the-middle attack (MITM)*: An attack in which an attacker is able to read, insert and modify at will messages between two parties without either party knowing that the link between them has been compromised. The attacker must be able to observe and intercept messages going between the two victims
- *IP address Spoofing*: refers to the creation of IP packets with a forged (spoofed) source IP address with the purpose of concealing the identity of the sender or impersonating another computing system.
- *Phishing*: An attempt to criminally and fraudulently acquire sensitive information, such as usernames, passwords and credit card details, by masquerading as a trustworthy entity in an electronic communication.

Countermeasures

- Be skeptical of e-mails indicating that you need to make changes to your accounts or warnings indicating that accounts will be terminated without you doing some type of activity online.
- Call the legitimate company to find out if this is a fraudulent message.
- Review the address bar to see if the domain name is correct.
- When submitting any type of financial information or credential data, an SSL connection should be set up, which is indicated in the address bar and a closed-padlock icon in the browser at the bottom-right corner.

Shoulder Surfing

- Shoulder surfing refers to using direct observation techniques, such as looking over someone's shoulder, to get information. Shoulder surfing is particularly effective in crowded places because it's relatively easy to observe someone as they:
 - Fill out a form

- Enter their PIN at an automated teller machine or a POS Terminal
- Enter passwords at a cybercafe, public and university libraries, or airport kiosks.

Object Reuse

Object reuse issues pertain to reassigning to a subject media that previously contained one or more objects.

The sensitive information that may be left by a process should be securely cleared before allowing another process the opportunity to access the object. This ensures that information not intended for this individual or any other subject is not disclosed.

For media that holds confidential information, more extreme methods should be taken to ensure that the files are actually gone, not just their pointers.

Countermeasures

- Sensitive data should be classified by the data owners.
- How the data is stored and accessed should also be strictly controlled and audited by software controls.
- Before allowing one subject to use media that was previously used, the media should be erased or degaussed. If media holds sensitive information and cannot be purged, there should be steps on how to properly destroy it so that there is no way for others to obtain this information.

Data Remanence

Data remanence is the residual representation of data that has been in some way been nominally erased or removed. This residue may be due to data being left intact by a nominal delete operation, or through physical properties of the storage medium.

Data remanence may make inadvertent disclosure of sensitive information possible, should the storage media be released into an uncontrolled environment.

Counter measures

- Methods to Countermeasure
 - Overwriting
 - A common method used to counter data remanence is to overwrite the storage medium with new data. This is often called a wiping or shredding a file or disk. The simplest overwrite technique writes the same data everywhere -- often just a pattern of all zeros. At a minimum, this will prevent the data from being retrieved simply by reading from the medium again, and thus is often used for clearing.
 - Degaussing
 - Degaussing is the removal or reduction of a magnetic field. Applied to magnetic media, degaussing may purge an entire media element quickly and effectively
 - Degaussing often renders hard disks inoperable, as it erases low-level formatting which is only done at the factory, during manufacture.
 - Encryption
 - Encrypting data before it is stored on the medium may mitigate concerns about data remanence.
 - Encryption may be done on a file-by-file basis, or on the whole disk.
 - Physical destruction

- Physical destruction of the data storage medium is generally considered the most certain way to counter data remanence, although also at the highest cost.

Backdoor/Trapdoor

A backdoor is a malicious computer program or particular means that provide the attacker with unauthorized remote access to a compromised system exploiting vulnerabilities of installed software and bypassing normal authentication.

A backdoor works in background and hides from the user. It is very similar to a virus and therefore is quite difficult to detect and completely disable.

A backdoor is one of the most dangerous parasite types, as it allows a malicious person to perform any possible actions on a compromised computer. The attacker can use a backdoor to:

- spy on a user,
- manage files,
-
- install additional software or dangerous threats,
- control the entire system including any present applications or hardware devices,
- shutdown or reboot a computer or
- attack other hosts.

Countermeasure

- Powerful antivirus and anti-spyware products

Dictionary Attacks

Dictionary attacks are launched by programs which are fed with a lists (dictionaries) of commonly used words or combinations of characters, and then compares these values to capture passwords. Once the right combination of characters is identified, the attacker can use this password to authenticate herself as a legitimate user.

Sometimes the attacker can even capture the password file using this kind of activity.

Countermeasures

To properly protect an environment against dictionary and other password attacks, the following practices should be followed:

- Do not allow passwords to be sent in cleartext.
- Encrypt the passwords with encryption algorithms or hashing functions.
- Employ one-time password tokens.
- Use hard-to-guess passwords.
- Rotate passwords frequently.
- Employ an IDS to detect suspicious behavior.
- Use dictionary cracking tools to find weak passwords chosen by users.
- Use special characters, numbers, and upper- and lowercase letters within the password.
- Protect password files.

Bruteforce Attacks

- Brute force is defined as “trying every possible combination until the correct one is identified.”
- The most effective way to uncover passwords is through a hybrid attack, which combines a dictionary attack and a brute force attack

- A brute force attack is also known as an exhaustive attack.
- These are usually used for wardialing in hopes of finding a modem that can be exploited to gain unauthorized access.

Countermeasures

For phone brute force attacks, auditing and monitoring of this type of activity should be in place to uncover patterns that could indicate a war dialing attack:

- Perform brute force attacks to find weaknesses and hanging modems.
- Make sure only necessary phone numbers are made public.
- Provide stringent access control methods that would make brute force attacks less successful.
- Monitor and audit for such activity.
- Employ an IDS to watch for suspicious activity.
- Set lockout thresholds.

Social Engineering

Social engineering is a collection of techniques used for manipulation of the natural human tendency to trust in order to obtain information that will allow a hacker to gain unauthorized access to a valued system and the information that resides on that system.

Forms of a Social engineering attack

- Physical: the workplace, the phone, your trash, and even on-line
- Psychological: Persuasion
- Reverse Social Engineering

Countermeasures

- Having proper security policies in place which addresses both physical and psychological aspects of the attack
- Providing proper training to employees, helpdesk personnel

Other threats can affect hardware, software, and the information you store include:

- Viruses are designed so that they can be easily transmitted from one computer or system to another. Often sent as email attachments, viruses corrupt and co-opt data, interfere with your security settings, generate spam, and may even delete content.
- Computer worms are similar; they spread from one computer to the next by sending themselves to all of the user's contacts and subsequently to all contacts' contacts.
- Trojans. These malicious pieces of software insert themselves into a legitimate program. Often, people voluntarily let trojans into their systems in email messages from a person or an advertiser they trust. As soon as the accompanying attachment is open, your system becomes vulnerable to the malware within.
- Bogus security software that tricks users into believing that their system has been infected with a virus. The accompanying security software that the threat actor provides to fix the problem causes it.
- The adware tracks your browsing habits and causes particular advertisements to pop up. Although this is common and often something you may even agree to, adware is sometimes imposed upon you without your consent.

- Spyware is an intrusion that may steal sensitive data such as passwords and credit card numbers from your internal systems.
- Phishing attacks are social engineering infiltrations whose goal is to obtain sensitive data: passwords and credit card numbers incorrectly. Via emails or links coming from trusted companies and financial institutions, the hacker causes malware to be downloaded and installed.
- SQL injections are network threats that involve using malicious code to infiltrate cyber vulnerabilities in data systems. As a result, data can be stolen, changed, or destroyed.
- Man-in-the-middle attacks involve a third party intercepting and exploiting communications between two entities that should remain private. Eavesdropping occurs, but information can be changed or misrepresented by the intruder, causing inaccuracy and even security breaches.
- Rootkit tools gain remote access to systems without permission and can lead to the installation of malware and the stealing of passwords and other data.

Examples of Cyber Attacks

Timeline chronicles ~ some cyber incidents out of 200 cyber incidents targeting financial institutions since 2007

- Beanstalk Farms cryptocurrency theft

On April 17, 2022, the decentralised finance platform Beanstalk Farms lost \$180 million in a cryptocurrency heist.

- TransUnion SA data breach

March 17 2022 Credit bureau TransUnion SA suffered a cyber attack which saw around three million customer's data stolen by a criminal third party.

- Moscow Stock Exchange and Sberbank cyber attack

On February 28, 2022, the Moscow Stock Exchange and Sberbank, Russia's largest lender, were hit by DDoS attacks that took their websites offline.

- Aon ransomware attack

On February 25, 2022, global insurance and reinsurance broker, Aon was hit by a ransomware attack, causing limited disruption to a number of their services.

- OCBC phishing scam

On December 23, 2021, around 790 banking customers of Singaporean bank OCBC were targeted in a phishing scam resulting in a loss of at least \$13.7 million.

- AscendEX hot wallet breach

On December 12, 2021, crypto exchange AscendEX lost \$77.7 million in a breach of its hot wallet.

- BadgerDAO DeFi protocol hack

On December 2, 2021, decentralised finance ("DeFi") protocol BadgerDAO was hit by a cyber attack in which hackers stole \$120.3 million in crypto.

- Ecuadorian Pichincha Bank disrupted by cyber attack

On October 10, 2021, Pichincha Bank in Ecuador was hit by a cyber attack that disrupted customers' access to bank services, including their online and mobile app tools.

- Taiwanese DeFi Platform hit by cyber attack

On August 30, 2021, Cream Finance, a Taiwanese decentralised finance platform, lost over \$29 million in cryptocurrency assets to hackers.

- FBI Attributes Loss of \$4 billion to Cybercrime

On March 17, 2021, the FBI released its Internet Crime Report 2020 which stated that American victims reported \$4.2 billion in losses as a result of cybercrime and internet fraud to the FBI last year.

- Indonesian Fintech Data Breach

On October 31, Indonesian fintech company Cermati reported 2.9 million users' information was leaked and sold in a hacker forum.

- Payments Processor Juspay Data Leak

On August 18, 2020, payments processor Juspay's was hacked through a compromised server, resulting in the leak of over 100 million debit and credit card users.

- Finance Sector RDoS Campaign

On August 17, Akamai, a global content delivery network, reported an ongoing campaign of RDoS (Ransom DDoS) attacks targeting the financial sector and other businesses.

- NetWalker Ransomware Attacks

On August 4, 2020, McAfee reported that ransomware-as-a-service (RaaS) provider NetWalker had made \$25 million over the previous five months through ransomware attacks.

- Norfund Business Email Compromise

On May 13, Norfund, Norway's state investment fund, was subject to a \$10 million heist that involved business email compromise.

- South Korean and US Payment Card Leak

On April 9, 2020, a cache of 400,000 payment card records from banks in South Korea and the U.S. were uploaded to a well-known underground marketplace.

- Cardplanet Fraud

On November 13, 2019, the United States charged a Russian man for running 'Cardplanet,' a card trading platform worth almost \$20 million USD that buys and sells stolen payment card details.

- Bank of Valletta

On February 13 2019, the Bank of Valletta (BOV), Malta's largest and oldest bank, shut down operations after an attempted theft of €13 million.

- Bancomext Attempted SWIFT Heist

On January 9, 2018, attackers attempted to use fraudulent SWIFT transactions to steal \$110 million from Bancomext, Mexico's state-owned trade bank, but the money was ultimately recovered.

Costa Rican Financial Institution Attempted Theft

In January 2018, attackers attempted to steal \$19 million from a private Costa Rican financial institution.

- Standard Bank Theft

On May 15, 2016, attackers stole \$19 million from South Africa's Standard Bank by making 14,000 withdrawals over 3 hours from 1,700 ATMs across Japan.

Guatemalan Financial Institution Theft

In December 2015, attackers stole \$16 million from a Guatemalan financial institution.

- Bank of the West DDoS Attack

On Christmas Eve 2013, Bank of the West was the victim of a DDoS attack used to disguise \$900,000 in fraudulent transfers out of accounts belonging to Ascent Builders, a Californian construction firm.

- Postbank Heist

From January 1-3 2020, hackers targeted Postbank, a division of the South African Post Office, breaching the organization's IT system and siphoning off cash into dummy accounts.

2.3. RISK

Risk is the likelihood of a threat agent taking advantage of vulnerability and the corresponding business impact. Reducing vulnerability and/or threat reduces the risk.

Risk is the probability of loss of asset, exposure to threat, and potential damage from a cyberattack. It is basically the meeting point of threat and vulnerability.

E.g.: If a firewall has several ports open, there is a higher likelihood that an intruder will use one to access the network in an unauthorized method.

- Exposure

An exposure is an instance of being exposed to losses from a threat agent.

Vulnerability exposes an organization to possible damages.

E.g.: If password management is weak and password rules are not enforced, the company is exposed to the possibility of having users' passwords captured and used in an unauthorized manner.

- Countermeasure or Safeguard

It is an application or a software configuration or hardware configuration or a procedure that mitigates the risk.

E.g.: strong password management, a security guard, access control mechanisms within an operating system, the implementation of basic input/output system (BIOS) passwords, and security-awareness training.

Once we know an asset's vulnerabilities and threats, we can determine how much risk is posed to the asset owner. This measure is the combination of the likelihood that a threat exploits a vulnerability and the scale of harmful consequences.

$\text{Risk} = (\text{Probability that a threat occurs}) * (\text{Cost to the asset owner})$

The Relation between vulnerability, risk and threat

Example 1

If a company has antivirus software but does not keep the virus signatures up-to-date, this is vulnerability. The company is vulnerable to virus attacks.

The threat is that a virus will show up in the environment and disrupt productivity.

The likelihood of a virus showing up in the environment and causing damage is the risk.

If a virus infiltrates the company's environment, then vulnerability has been exploited and the company is exposed to loss.

The countermeasures in this situation are to update the signatures and install the antivirus software on all computers

Threat Agent gives rise to Threat exploits Vulnerability leads to Risk can damage Assets and causes an Exposure can be counter measured by Safeguard directly effects Threat Agent

Example 2

Target: A bank contains money.

Threat: There are individuals who want, or need, additional money.

Vulnerability: The bank uses software that has a security flaw.

Exposure: 20% of the bank's assets are affected by this flaw.

Exploit: By running a small snippet of code (malware), the software can be accessed illegally.

Threat Agent: There are hackers who have learned how to use this malware to control the bank's software.

Exploitation: The hackers access the software using the malware and steal money.

Impact: The bank loses monetary assets, reputation, and future business.

Risk: The likelihood that a hacker will exploit the bank's software vulnerability and impact the bank's reputation and monetary resources.

Risk Assessment/Analysis

Risk analysis is a method of identifying vulnerabilities and threat and assessing the possible damage to determine where to implement security safeguards

Why Risk Analysis?

- ✓ To ensure that security is cost effective, relevant, timely, and responsive to threat.
- ✓ To provide a cost/benefit comparison, this compares the annualized cost of safeguards to the potential cost of loss.
- ✓ Help integrate the security program objectives with the company's business objectives and requirements
- ✓ To provide an economic balance between the impact of the threat and the cost of the countermeasure.

Analyze the risk

There are two approaches of analyzing risk

- ✓ Quantitative Approach
- ✓ Qualitative Approach

A Quantitative Approach to Risk Analysis

Quantitative analysis uses risk calculations that attempt to predict the level of monetary losses and percentage of chance for each type of threat.

Quantitative risk analysis also provides concrete probability percentages when determining the likelihood of threats.

Each element within the analysis (asset value, threat frequency, severity of vulnerability, impact damage, safeguard costs, safeguard effectiveness, uncertainty, and probability items) is quantified and entered into equations to determine total and residual risks.

Sample Steps for a Quantitative Risk Analysis

Step 1: Assign Value to Assets- For each asset, answer the following questions to determine its value

- What is the value of this asset to the company?
- How much does it cost to maintain?
- How much does it make in profits for the company?
- How much would it be worth to the competition?
- How much would it cost to re-create or recover?
- How much did it cost to acquire or develop?
- How much liability are you under pertaining to the protection of this asset?

Step 2: Estimate Potential Loss per Threat- To estimate potential losses posed by threats, answer the following questions:

- What physical damage could the threat cause and how much would that cost?
- How much loss of productivity could the threat cause and how much would that cost?
- What is the value lost if confidential information is disclosed?
- What is the cost of recovering from this threat?
- What is the value lost if critical devices were to fail?
- What is the single loss expectancy (SLE) for each asset, and each threat?

Step 3: Perform a Threat Analysis- Take the following steps to perform a threat analysis

- Gather information about the likelihood of each threat taking place from people in each department, past records, and official security resources that provide this type of data.
- Calculate the annualized rate of occurrence (ARO), which is how many times the threat can take place in a 12-month period.

Step 4: Derive the Overall Loss Potential per Threat-To derive the overall loss potential per threat, do the following:

- Combine potential loss and probability.
- Calculate the annualized loss expectancy (ALE) per threat by using the information calculated in the first three steps.
- Choose remedial measures to counteract each threat.
- Carry out cost/benefit analysis on the identified countermeasures.

Step 5: Reduce, Transfer, or Accept the Risk- For each risk, you can choose whether to reduce, transfer, or accept the risk:

Risk reduction methods e.g. Install security controls and components, provide early detection methods to catch the threat as it's happening and reduce the possible damage it can cause.

Risk transfer- Buy insurance to transfer some of the risk, for example.

Risk acceptance- Live with the risks and spend no more money toward protection.

Quantitative Risk Analysis Metrics

- Single loss expectancy (SLE) - The amount of loss due to a single occurrence of a threat.
- Annualized loss expectancy (ALE) - The estimated loss per annum.
- Exposure factor (EF) - Represents the percentage of loss a realized threat could have on a certain asset.
- Annualized rate of occurrence (ARO) – It is the value that represents the estimated frequency of a specific threat taking place within a one-year timeframe. It can range from 0.0 to 1.0.

Results of a Quantitative Risk Analysis

The following is a short list of what generally is expected from the results of a risk analysis

- Monetary values assigned to assets
- Comprehensive list of all possible and significant threats
- Probability of the occurrence rate of each threat
- Loss potential the company can endure per threat in a 12-month time span
- Recommended safeguards, countermeasures, and actions analysis.

A Qualitative Approach to Risk Analysis

- In Qualitative approach, we walk through different scenarios of risk possibilities and rank the seriousness of the threats and the validity of the different possible countermeasures.
- The Qualitative analysis techniques include judgment, best practices, intuition, and experience.
- Qualitative Risk Analysis Techniques
- Delphi -A group decision method used to ensure that each member gives an honest opinion of what he or she thinks the result to a particular threat will be. This method is used to obtain an agreement on cost, loss values, and probabilities of occurrence without individuals having to agree verbally.

The risk analysis team will determine the best technique for the threats that need to be assessed and the culture of the company and individuals involved with the analysis.

Ways to deal with Risk

There are four basic ways of dealing with risks:

- Transfer it: If a company's total or residual risk is too high and it purchases an insurance then it is transfer of risk to the insurance company
- Reject it: If a company is in denial about its risk or ignore it, it is rejecting the risk
- Reduce it: If a company implements countermeasures, it is reducing the risk
- Accept it: If a company understands the risk and decides not to implement any kind of countermeasures it is accepting the risk. And this is actually what all computer systems boil down to. There is no way to mitigate the risk if the system is going to connect to the internet. Having only one user without any networking with others computer systems is the closet you can ever get to not having any risks.